

Threat Modeling di una Agentic Filler Pipeline per Digital Human in tempo reale

Progetto per il corso di
Sicurezza delle Architetture Data Intensive (6 CFU)

Prof. Ernesto Damiani

Università degli Studi di Milano
Corso di Laurea Magistrale in Sicurezza Informatica

Studenti: Marta Finazzi
Alessio Bonora

Luglio 2026

Indice

1	Abstract	1
2	Introduzione e obiettivi	1
2.1	Contesto	1
2.2	Caratterizzazione Agentica del Sistema	2
2.3	Obiettivi dell'analisi	2
3	Scope e metodologia	3
3.1	Oggetto dell'analisi	3
3.2	Processo di threat modeling	3
3.3	Metodologia STRIDE-AI e quadro delle proprietà CIA ³ -R	3
4	Descrizione della pipeline agentica	5
4.1	Architettura della pipeline agentica	5
4.2	Fast-Brain Agent	5
4.3	Deep-Brain Agent e componenti di supporto	6
4.4	Orchestrazione e gestione dello stato	6
5	Data Flow Diagram e trust boundary	7
5.1	DFD di livello 0	7
5.2	DFD di livello 1	7
6	Asset Model	8
6.1	Data Assets	8
6.2	Model Assets	10
6.3	Considerazioni sulla classificazione	12
7	Analisi delle Minacce basata su OWASP Agentic Top 10	13
8	Risk Prioritization	14
8.1	Criteri di Valutazione e Metodologia	14
8.2	Matrice Qualitativa di Rischio	15
8.3	Priorità dei rischi principali	15
9	Scenari di minaccia prioritari	15
9.1	Scenario 1 — Goal hijack del Fast-Brain	15
9.2	Scenario 2 — Feedback poisoning persistente	16
9.3	Scenario 3 — Identity and privilege abuse tra agenti	16
9.4	Scenario 4 — Tampering e replay dei messaggi inter-agent	17
9.5	Scenario 5 — Voice clone abuse e human-agent trust exploitation	17

10 Controlli secondo le sette precauzioni	18
10.1 Precauzione 1 — Least Agency	18
10.2 Precauzione 2 — Guardrail deterministici e HITL	18
10.3 Precauzione 3 — Sandboxing e controllo granulare degli accessi	19
10.4 Precauzione 4 — Audit trail completo e immutabile	19
10.5 Precauzione 5 — Supply chain control	19
10.6 Precauzione 6 — Continuous execution monitoring	19
10.7 Precauzione 7 — Audit periodici ispirati ad AIVSS	20
11 Secure architecture proposal	20
11.1 Fail-safe behavior	21
12 Trade-off sicurezza–latenza	21
13 Piano di validazione sperimentale	22
13.1 Esperimento A — Fast-Brain security harness	22
13.2 Esperimento B — Feedback poisoning simulation	22
13.3 Esperimento C — Sicurezza dei messaggi inter-agent	23
14 Rischio residuo	24
15 Limitazioni	24
16 Conclusioni	25
A JSON Schema semplificato del Fast-Brain	25
B Formato sicuro del messaggio inter-agent	26
C Matrice di tracciabilità	26

1 Abstract

Questo progetto presenta il threat modeling di una pipeline agentica progettata per ridurre la latenza percepita durante l'interazione con un digital human. L'architettura adotta un modello *dual-brain*: un **Fast-Brain Agent** produce rapidamente un filler verbale e un trigger gestuale, mentre un **Deep-Brain Agent** elabora la risposta principale tramite LLM, RAG e memoria contestuale. I due percorsi sono eseguiti in parallelo e coordinati da un orchestratore che gestisce priorità, transizione audio-video, fallback e sincronizzazione.

L'analisi è deliberatamente centrata sulla natura **agantica** del sistema. Come indicato per questa traccia, non viene applicata una FMEA: le minacce sono identificate direttamente a partire da asset, agenti, azioni, tool, memorie, identità e trust boundary. Il processo combina **STRIDE-AI**, le proprietà di sicurezza CIA³-R e l'**OWASP Top 10 for Agentic Applications 2026**. La relazione definisce lo scope, esplicita le assunzioni architetturali, costruisce un attacker model, valuta l'applicabilità dei rischi OWASP e approfondisce cinque scenari prioritari: goal hijack del Fast-Brain, poisoning persistente del feedback, abuso di identità e privilegi tra agenti, tampering/replay dei messaggi inter-agent e sfruttamento della fiducia tramite voice cloning.

Le mitigazioni sono organizzate secondo le sette precauzioni discusse nel corso: Least Agency, guardrail deterministici e Human-in-the-Loop, sandboxing e controllo granulare degli accessi, audit trail immutabile, controllo della supply chain, monitoraggio continuo e audit periodici ispirati ad AIVSS. Il risultato è una proposta di architettura sicura che preserva il requisito di bassa latenza mediante controlli sincroni deterministici, fallback fail-safe e controlli più costosi spostati fuori dal percorso critico.

2 Introduzione e obiettivi

2.1 Contesto

Nelle architetture tradizionali per digital human embodied, il flusso di elaborazione sequenziale STT → LLM → TTS → Lip-Sync → WebRTC introduce una latenza complessiva che varia da diversi secondi fino a 2–4 minuti nei casi di rendering video complessi. Tale ritardo risulta del tutto incompatibile con i requisiti di un'interazione naturale e conversazionale, per la quale la latenza percepita di prima risposta deve rimanere inferiore a circa 800 ms [1, 3].

Per superare questo limite e mascherare i tempi d'attesa, l'architettura adotta una pipeline agentica *dual-brain* articolata su due percorsi paralleli (*Instant Path* e *Background Path*). Un **Fast-Brain Agent** genera filler immediati e contestuali (durata 1–3 secondi, come cenni del capo o brevi locuzioni interietive) per ridurre l'intervallo percepito dall'utente, mentre un **Deep-Brain Agent** elabora in background la risposta articolata [1, 3].

L'istanza applicativa considerata come caso di studio implementa l'avatar embodied di **Al-Hakima Umm Saif**, una figura tradizionale anziana delle comunità oasiche di Liwa e della costa degli Emirati Arabi Uniti [4]. L'agente è caratterizzato da:

- una spiccata personalità materna, empatica e rassicurante (*Motherly & Warm Affection*) [4];
- l'uso del dialetto emiratino locale (regione di Liwa/Al Ain) intervallato da formule religiose e proverbi tradizionali [5];
- l'erogazione di consigli di benessere e rimedi erboristici popolari (es. *za'atar*, *sider*, *harmal*) a supporto delle risposte [5];
- una pipeline RAG multilingue e multimodale basata su un indice vettoriale **FAISS** (*Facebook AI Similarity Search*) — impiegato per la ricerca ad alta velocità di similarità semantica tra vettori

densi generati tramite il modello di embedding **multilingual-e5-large** — affiancato da un LLM **Falcon-Arabic-7B**, sintesi vocale TTS con voce clonata (*Therapist WAV*) e un motore video cinematografico (Veo 3.1) coordinato da un sistema di *Lip-Syncing* e *Swap Manager* per la transizione fluida tra filler e video finale [1, 3].

Sebbene queste caratteristiche comportamentali massimino il realismo e l’immersività, esse amplificano notevolmente il potere persuasivo dell’avatar e l’impatto emotivo sull’utente. Di conseguenza, l’autenticità del contenuto, la safety dei consigli dispensati e la tutela della fiducia dell’utente (*Human-Agent Trust*) diventano requisiti di sicurezza e di threat modeling prioritari [4, 5].

2.2 Caratterizzazione Agentica del Sistema

Un sistema si definisce *agentic* quando combina capacità di inferenza autonoma e azione, interagisce con memorie persistenti e strumenti esterni, e coordina componenti eterogenei senza richiedere una supervisione umana passo-passo [2, 10]. La pipeline analizzata soddisfa integralmente tali requisiti attraverso le seguenti dinamiche operative e decisionali:

- **Fast-Brain Agent**: interpreta i token parziali in streaming provenienti dal modulo STT e decide in modo autonomo il filler verbale, la risposta emotiva e il trigger gestuale o animativo di accompagnamento (es. **GAZE_UP_LEFT**, **PREPARING_HERBS**) [1, 4];
- **Deep-Brain Agent**: gestisce in autonomia l’intero ciclo di ragionamento RAG, esegue la *query expansion* sull’indice vettoriale FAISS, recupera il contesto storico, applica il *System Prompt* di personalità e invoca la generazione multimodale [1];
- **Orchestratore e Swap Manager**: monitora in tempo reale lo stato di avanzamento dei due percorsi paralleli, prende decisioni dinamiche su timeout e *fallback*, gestisce la commutazione trasparente del flusso video dal filler al video sintetizzato e coordina lo stacco audio-visivo [1];
- **Ciclo di Feedback e Memoria Persistente**: raccoglie segnali di interazione impliciti (es. *replay*) ed espliciti per aggiornare e riorganizzare dinamicamente il pool di *few-shot examples* e il *ranking* dei documenti in FAISS per le sessioni future [1];
- **Invocazione Strategica di Tool Esterni**: orchestra l’esecuzione di una catena articolata di microservizi specializzati (STT, TTS con *voice cloning*, modello video cinematografico Veo 3.1, *Lip-Syncing* e modelli LLM) [1, 3].

2.3 Obiettivi dell’analisi

Gli obiettivi sono:

1. definire con precisione architettura, scope e assunzioni;
2. identificare gli asset Data, Model e gli asset agentici di supporto;
3. individuare minacce concrete senza passare da una FMEA;
4. classificare le minacce tramite STRIDE-AI e OWASP Agentic;
5. prioritizzare i rischi in base a likelihood, impact e amplificatori agentici;
6. proporre controlli coerenti con le sette precauzioni del corso;
7. progettare una secure architecture compatibile con il vincolo real-time;
8. definire un piano sperimentale riproducibile senza inventare risultati non misurati.

Scelta metodologica. La FMEA non viene applicata. Il threat model parte direttamente da asset, agenti, trust boundary, identità, memorie, tool e azioni. La FMEA rimane appropriata per analizzare guasti e failure mode di pipeline AI tradizionali, ma non è richiesta per questa traccia agentica.

3 Scope e metodologia

3.1 Oggetto dell'analisi

L'oggetto è la **pipeline agentica dual-brain** che maschera la latenza della generazione audiovisiva. Il Deep-Brain usa internamente il percorso RAG e i servizi multimediali; tali componenti sono inclusi soltanto nella misura in cui rappresentano memorie, tool o superfici d'attacco raggiungibili dagli agenti.

Sono inclusi:

- input vocale o testuale, VAD e streaming STT;
- Fast-Brain e Deep-Brain;
- orchestratore e messaggi inter-agent;
- RAG, memoria di sessione, eventuale memoria persistente e feedback;
- TTS filler, TTS principale, voice cloning, generazione video e lip-sync;
- identità di servizio, credenziali, policy, log e artefatti intermedi;
- output audio-video verso l'utente.

Sono fuori scope, salvo che vengano introdotti in implementazioni future:

- code interpreter, shell e valutazione dinamica di codice generato;
- accesso dell'agente a sistemi amministrativi esterni;
- modifica autonoma di risorse cloud o database operativi;
- strumenti non descritti nella traccia.

3.2 Processo di threat modeling

Il processo adottato è:

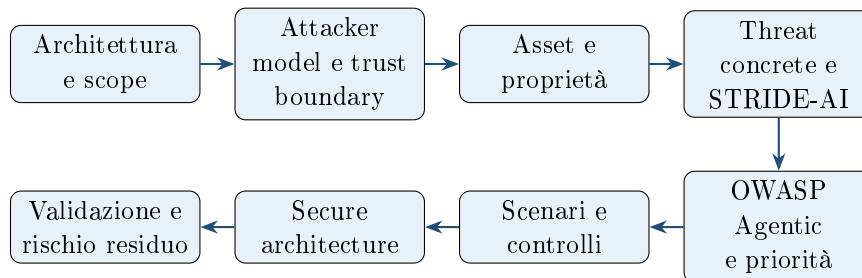


Figura 1: Processo adottato per la pipeline agentica.

La metodologia STRIDE-AI mantiene un approccio asset-centered e adatta le categorie classiche di STRIDE agli asset AI/ML [6, 7]. Per i rischi specifici degli agenti viene usata la tassonomia OWASP Agentic 2026. Le sette precauzioni del corso sono usate come struttura della strategia di mitigazione [2].

3.3 Metodologia STRIDE-AI e quadro delle proprietà CIA³-R

Per valutare in modo sistematico le vulnerabilità della pipeline agentica, l'analisi adotta la metodologia **STRIDE-AI** [6, 7]. A differenza della FMEA tradizionale, che valuta i guasti operativi o fisici, STRIDE-AI adotta un approccio *asset-centered*: identifica le minacce a partire dalla violazione delle proprietà di sicurezza sugli asset AI/ML e sugli agenti autonomi [6, 7].

La metodologia adatta le sei categorie classiche dello schema STRIDE di Microsoft al contesto delle applicazioni agentiche e generative, correlandole alle sette proprietà di sicurezza del modello esteso CIA³-R [7].

Proprietà di sicurezza considerate (CIA³-R)

Nel corso dell’analisi e nelle relative tabelle degli asset e del catalogo minacce, viene adottata la seguente notazione formale per le proprietà di sicurezza potenzialmente violate:

C – Confidentiality Le informazioni devono essere accessibili esclusivamente agli utenti, agli agenti e ai servizi autorizzati.

I – Integrity Dati, configurazioni, modelli e risultati non devono essere alterati in modo accidentale o non autorizzato.

A – Availability Gli asset e i servizi devono essere disponibili nei tempi richiesti dalla pipeline, con particolare attenzione ai vincoli di latenza dell’Instant Path.

Au – Authentication Deve essere verificata l’identità degli utenti, degli agenti e dei servizi che partecipano all’elaborazione.

Az – Authorization Ogni componente deve poter accedere soltanto alle risorse ed eseguire soltanto le operazioni necessarie al proprio obiettivo.

Ac – Accountability Le operazioni devono poter essere attribuite in modo verificabile all’utente, all’agente o al servizio che le ha eseguite.

R – Non-repudiation Un soggetto o componente non deve poter negare di avere generato un messaggio, modificato un dato, invocato un servizio o autorizzato una transizione.

Tabella 1: Tassonomia STRIDE-AI e trasposizione nel contesto agentico Dual-Brain [6].

Categoria	Definizione Classica	Trasposizione nel Sistema Agentico Dual-Brain	Proprietà Violata
Spoofing	Impersonamento non autorizzato di un’identità legittima.	Voice cloning non autorizzato per impersonare l’avatar; spoofing dell’identità degli agenti o del segnale <i>Video Ready Signal</i> .	Au, R
Tampering	Alterazione non autorizzata di dati, prompt o codice.	Indirect Prompt Injection nei token parziali; poisoning della memoria RAG, del vettore FAISS o del feedback.	I
Repudiation	Impossibilità di attribuire in modo certo un’azione a un soggetto.	Assenza di audit log immutabili per verificare se un output dannoso sia stato generato dall’agente o sollecitato da prompt avversari.	Ac, R
Information Disclosure	Fuga o esposizione non autorizzata di dati riservati.	Cross-session memory leakage; esfiltrazione di PII o dei prompt interni di personalità tramite prompt leakage.	C
Denial of Service	Interruzione della disponibilità dei servizi o delle risorse.	Saturazione computazionale tramite prompt complessi; attacchi di desincronizzazione del ciclo di stato (<i>Double-Speak</i>).	A
Elevation of Privilege	Ottenimento di privilegi o capacità superiori a quelle autorizzate.	<i>Goal Hijacking</i> del Fast-Brain per invocare tool non autorizzati; bypass dei guardrail deterministici; escalation di privilegi inter-agente.	Az

4 Descrizione della pipeline agentica

4.1 Architettura della pipeline agentica

La Figura 2 illustra l'architettura complessiva della pipeline agentica per la generazione di video conversazionali. L'input dell'utente (vocale o testuale) viene intercettato dal **Request Router**, il quale duplica il flusso per avviare in parallelo due percorsi concorrenti con requisiti e tempistiche differenti:

- **Instant Path (Fast-Brain, 0–3 secondi)**: Ha l'obiettivo primario di azzerare la latenza percepita. Elabora lo streaming del testo parziale (*Partial Text Stream*) attraverso un classificatore d'intento (*Intent Classifier*) per identificare argomento ed emozione, selezionando istantaneamente filler verbali (es. formule colloquiali) e clip gestuali pre-renderizzate (*Pre-built Clips*) per la risposta immediata.
- **Background Path (Deep-Brain, 2–4 minuti)**: Elabora la richiesta completa ed effettua il ragionamento approfondito. Il percorso integra un'architettura RAG su indice vettoriale FAISS con modello Falcon-Arabic-7B, genera un video cinematografico parlante tramite Veo 3.1, applica il TTS con clonazione vocale e sincronizza il lip-sync. Al completamento del rendering, il componente invia un segnale di pronto (*Video Ready Signal*).

I due flussi convergono nello **Swap Manager**, il quale gestisce lo stitching dinamico ed esegue una transizione fluida (*seamless cut*) dal video di filler al video finale generato, assicurando l'assenza di discontinuità nei frame, sovrapposizioni audio o desincronizzazioni di sessione.

In basso, la timeline utente (*User Timeline*) evidenzia chiaramente la percezione dell'interazione: l'utente riceve un feedback visivo e verbale nei primi 0–3 s (*Filler*), mentre l'elaborazione di background prosegue fino alla riproduzione trasparente del video finale sintetizzato.

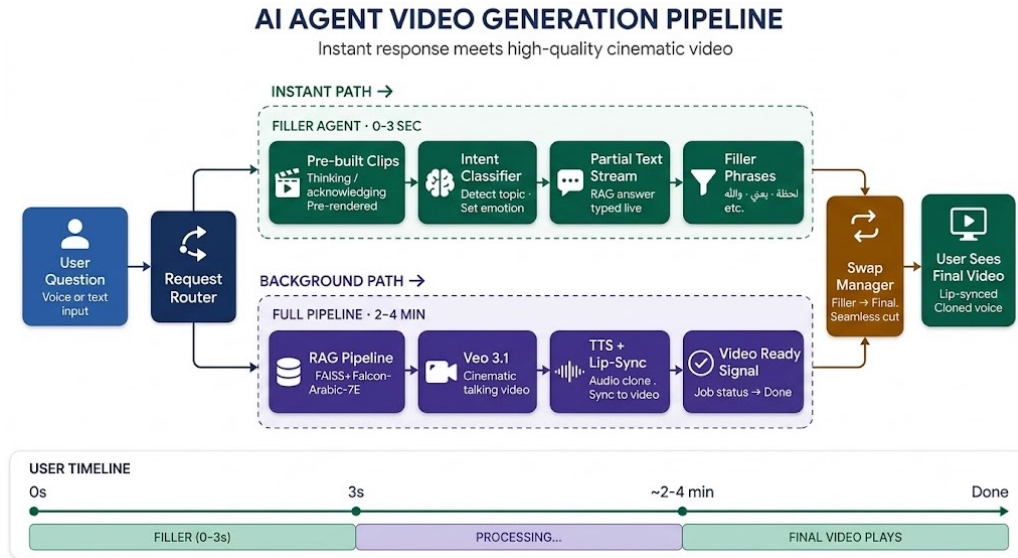


Figura 2: Architettura della pipeline agentica Dual-Brain.

4.2 Fast-Brain Agent

Come illustrato nel ramo superiore (*Instant Path*) della Figura 2, il Fast-Brain è progettato per generare un riconoscimento contestuale entro un budget temporale ridotto (< 800 ms). Il prompt di sistema limita rigorosamente il compito a un filler di massimo 12 parole e richiede un output JSON strutturato.

In applicazione del principio di *Least Agency*, il Fast-Brain viene limitato ai soli dati e privilegi indispensabili per il suo compito: riceve in input esclusivamente lo streaming del testo parziale e una

classificazione preliminare dell'intento (utilizzata per adattare il tono della risposta iniziale prima del completamento della frase).

Il suo output è circoscritto a tre soli campi: il testo del filler, la label d'intento e un trigger gestuale estratto da un insieme finito di animazioni pre-renderizzate. Per costruzione, al Fast-Brain è precluso l'accesso alla base di conoscenza RAG, alla memoria storica, ai database di feedback e ai moduli di clonazione vocale. Il componente non eroga risposte sostanziali, non richiede dati all'utente e non genera contenuti informativi autonomi.

Un esempio di output logico strutturato è il seguente:

Listing 1: Output logico del Fast-Brain.

```
{
  "session_id": "9f4b...",
  "intent": "complex_analytical",
  "trigger": "GAZE_UP_LEFT",
  "filler": "That is an important question; let me consider it carefully.",
  "sequence": 12
}
```

Il formato JSON non costituisce un confine di sicurezza sufficiente di per sé: prima di raggiungere i motori di sintesi vocale e animazione, l'output deve essere validato da un componente deterministico indipendente (*Output Validator*).

4.3 Deep-Brain Agent e componenti di supporto

Come illustrato nel ramo inferiore (*Background Path*) della Figura 2, il Deep-Brain riceve la trascrizione completa dell'utente e gestisce l'elaborazione sostanziale. Il suo flusso operativo comprende:

- query expansion e retrieval sull'indice vettoriale FAISS (accessibile via **RAG Retriever** esclusivamente in modalità *read-only*);
- recupero del contesto RAG completo di metadati e provenienza dei chunk;
- consultazione della memoria di sessione ed eventuale memoria contestuale;
- applicazione dei prompt di sistema e degli esempi *few-shot*;
- invocazione isolata del **Voice Service** (con accesso protetto ai soli embedding vocali autorizzati) e della generazione video multimodale.

La memoria persistente non può essere sovrascritta o modificata direttamente dall'utente tramite le interazioni conversazionali. Qualsiasi aggiornamento della base di conoscenza o del pool di esempi (*few-shot*) è gestito in modo isolato da un componente dedicato, il **Feedback Manager**. Quando l'utente fornisce un feedback (esplicito o implicito), questo non altera direttamente la memoria dell'agente: viene invece inviata una proposta di modifica al Feedback Manager. Tale proposta viene applicata all'indice RAG solo dopo essere stata convalidata da rigorose regole di sicurezza automatiche e, per gli aggiornamenti ad alto impatto, dalla supervisione diretta di un operatore umano (*Human-in-the-Loop*).

4.4 Orchestrazione e gestione dello stato

L'Orchestratore (che integra la logica dello *Swap Manager*) coordina l'esecuzione asincrona dei due percorsi senza esercitare un ruolo decisionale sui contenuti verbali. Esso implementa una macchina a stati esplicita e deterministica:

1. ricezione dell'input utente e apertura della sessione;
2. fork e avvio parallelo di Instant Path e Background Path;

3. validazione deterministica dell'output del Fast-Brain;
4. emissione del filler oppure attivazione del fallback statico;
5. ricezione del *Video Ready Signal* dal Deep-Brain;
6. transizione controllata (*stitching*) dal filler al video finale;
7. chiusura della sessione e scrittura dell'audit trail.

Questo approccio previene condizioni di gara come il fenomeno del *Double-Speak* (sovrapposizione di audio tra filler e risposta principale), trattando la sincronizzazione come un problema di integrità di stato gestito mediante lock logici, chiavi di idempotenza e timeout.

5 Data Flow Diagram e trust boundary

5.1 DFD di livello 0

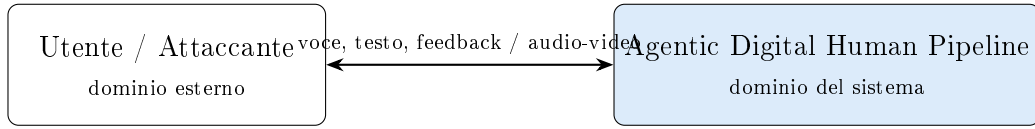


Figura 3: DFD livello 0.

5.2 DFD di livello 1

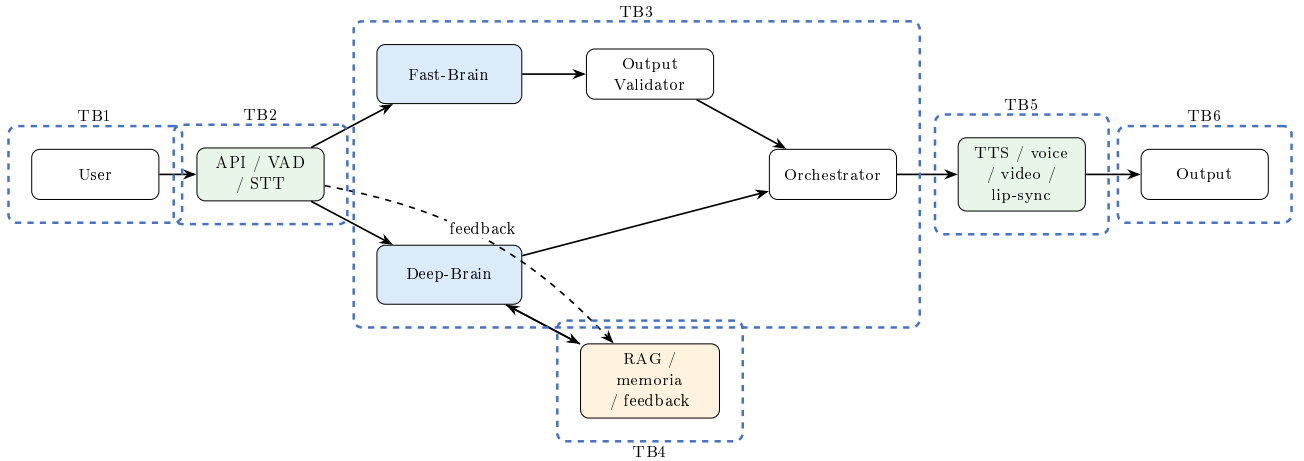


Figura 4: DFD livello 1 e principali trust boundary.

Tabella 2: Trust boundary e requisiti di sicurezza.

TB	Confine	Dati/azioni	Rischi dominanti
TB1	Utente esterno $\leftrightarrow$ edge	Voce, testo, feedback, session ID	Spoofing, prompt injection, flooding, feedback manipulation
TB2	Edge $\rightarrow$ agenti	Partial transcript, full transcript, intent preliminare	Truncation, goal hijack, PII leakage, session mix-up
TB3	Agenti $\leftrightarrow$ orchestratore	Filler, trigger, risposta, completion signal	Identity spoofing, tampering, replay, state desynchronization
TB4	Deep-Brain $\leftrightarrow$ RAG/memoria	Query, chunk, embedding, score, feedback update	Poisoning, cross-user leakage, unauthorized write
TB5	Orchestratore $\leftrightarrow$ media services	Testo, voice reference, prompt visuale, audio e video intermedi	Tool misuse, supply chain, provider disclosure, artifact tampering
TB6	Output $\rightarrow$ utente	Video, audio, metadata, provenance	Impersonazione, output tampering, assenza di disclosure AI

6 Asset Model

L'asset model identifica gli elementi della pipeline agentica che devono essere protetti e che saranno successivamente analizzati rispetto alle minacce della OWASP Top 10 for Agentic Applications 2026.

In accordo con la metodologia STRIDE-AI introdotta nella Sezione 3.3, gli asset sono suddivisi in due categorie principali:

- **Data Assets:** dati acquisiti, prodotti, memorizzati, recuperati o trasmessi durante l'esecuzione della pipeline;
- **Model Assets:** modelli di machine learning, prompt operativi e componenti logiche che determinano o controllano il comportamento agentic del sistema.

Per ciascun asset vengono analizzati il ruolo all'interno della pipeline, la rilevanza STRIDE-AI e le proprietà della matrice CIA³-R potenziale oggetto di violazione.

6.1 Data Assets

I *Data Assets* comprendono le informazioni e gli artefatti digitali che fluiscono attraverso la pipeline agentica o che ne alimentano il funzionamento. Essi includono gli input vocali e testuali dell'utente, le trascrizioni generate dallo STT, i documenti e la memoria di contesto per il RAG, gli artefatti audiovisivi intermedi e finali, i dati di sincronizzazione della sessione e i log di sistema.

Rientrano in questa categoria anche i materiali sorgente che definiscono l'identità del digital human (**Personality Source Artifacts**), intesi come asset informativi persistenti distinti dalle istruzioni operative inviate ai modelli a runtime.

La Tabella 3 illustra i Data Assets individuati, le relative minacce STRIDE-AI e le proprietà CIA³-R maggiormente esposte a rischio.

Tabella 3: Data Assets della pipeline agentica

Asset	Descrizione	STRIDE-AI Relevance	Proprietà CIA ³ -R Violate
D1 – User Audio / Input Streams	Flussi vocali o testuali prodotti dall'utente e ricevuti dalla pipeline, inclusi il segnale originale e i metadati di sessione.	S: iniezione di flussi vocali o messaggi contraffatti mediante session hijacking. T: manipolazione del segnale audio o del testo in transito prima dell'elaborazione. I: intercettazione non autorizzata (eavesdropping) del flusso audio dell'utente.	C, I, Au
D2 – Short Prompt Tokens & Partial Transcript	Primi token o frammenti della trascrizione inviati all'Instant Path per classificare l'intento e selezionare il filler.	T: alterazione dei primi token per forzare la classificazione di un intento errato. E: iniezione di istruzioni malevole nel partial transcript per deviare il comportamento del Fast-Brain.	I, Az
D3 – Full Transcript & Request	Trascrizione completa e normalizzata usata dal Background Path per produrre la risposta principale del Deep-Brain.	T: indirect prompt injection nel testo trascritto per manipolare le istruzioni inviate all'LLM. I: lettura non autorizzata dei prompt utente contenenti dati personali o sensibili.	C, I
D4 – RAG KB & Context Memory	Documenti, chunk, embedding, indici vettoriali FAISS, metadati e memoria di sessione/persistente.	T: avvelenamento della conoscenza (<i>data poisoning</i>) o manipolazione dei vettori nell'indice. I: accesso non autorizzato e fuga di dati riservati memorizzati nella Knowledge Base. E: escalation di privilegi per accedere a documenti o chunk riservati ad altri utenti.	C, I, Az
D5 – Behavioral Animation Triggers	Output strutturati che specificano il comportamento non verbale (ID clip, movimento occhi, gesti, stato emotivo).	T: manomissione dei trigger per forzare posture o espressioni dell'avatar inappropriate o offensive. D: iniezione di trigger invalidi o corrotti che mandano in crash il motore di animazione.	I, A
D6 – Response Transcripts	Testo del filler (Instant Path) e testo della risposta principale (Deep-Brain) inviati ai componenti TTS e video.	T: modifica in transito del testo generato prima che venga inviato al sintetizzatore vocale. I: estrazione non autorizzata dei testi di risposta contenenti dati o logica riservata.	C, I
D7 – Personality Source Artifacts	File sorgente contenenti leggenda del personaggio, tratti della personalità, tono, dialetto e regole stilistiche.	T: manomissione dei file sorgente della personalità per corrompere il comportamento globale del sistema. I: esfiltrazione degli artefatti della personalità e del sistema di regole protetto da IP.	C, I
D8 – Voice & Visual Identity Assets	Campioni vocali, voce embedding, immagini e video di riferimento per riprodurre l'identità dell'avatar.	S: espropriazione o riutilizzo non autorizzato dei dataset di identità per creare clone non autorizzati. I: accesso e sottrazione dei file di riferimento e degli embedding dell'identità visiva e vocale.	C, Au

Continua nella pagina successiva

Tabella 3 – continuazione

Asset	Descrizione	STRIDE-AI Relevance	Proprietà CIA ³ -R Violate
D9 – In- termediate Audio/Video	File e stream temporanei prodotti durante TTS, voice cloning, generazione video, lip-sync e composizione.	T : sostituzione o alterazione dei segmenti audio/video temporanei prima dello stitching. I : accesso ai file temporanei salvati nel buffer di sistema o nei dati di cache.	C, I
D10 – Coordination & Swap State	Messaggi e dati di coordinamento (session ID, job ID, timestamp, stato playback, Video Ready Signal).	S : invio di falsi segnali di sincronizzazione (<i>Video Ready Signal</i>) impersonando l'orchestratore. T : alterazione di session ID o timestamp per causare sovrapposizioni tra utenti o deserializzazione errata. E : manomissione dello stato di sessione per dirottare o scambiare i flussi multimediali.	I, A, Az
D11 – WebRTC Media Streams	Flusso audio-video finale trasmesso all'utente, inclusi pacchetti multimediali e dati di negoziazione sessione.	S : man-in-the-middle per impersonare l'agente o intercettare il canale di streaming finale. T : alterazione o iniezione di frame dannosi nei pacchetti multimediali WebRTC. I : intercettazione (eavesdropping) dei flussi multimediali in uscita rivolti all'utente.	C, I
D12 – Audit & Feedback Data	Log di richieste, decisioni, invocazioni, transizioni, provenance degli artefatti e feedback forniti dagli utenti.	T : cancellazione o alterazione delle righe di log per nascondere attività avversariali o malevole. R : manomissione della tracciabilità rendendo impossibile l'imputabilità e la forensic analysis.	I, Ac, R

6.2 Model Assets

I Model Assets comprendono i modelli utilizzati per analizzare, recuperare e generare contenuti, i prompt che ne definiscono il comportamento e la logica applicativa che coordina i due percorsi concorrenti.

La categoria è utilizzata in senso architetturale esteso. Comprende quindi non soltanto i pesi dei modelli di machine learning, ma anche prompt e componenti software che determinano obiettivi, vincoli, routing e sequenze operative del sistema agentic.

Tabella 4: Model Assets della pipeline agentica

Asset	Descrizione	STRIDE-AI Relevance	Proprietà CIA ³ -R Violate
M1 – Fast-Brain Agent e Intent Classifier	Modello a bassa latenza che analizza la trascrizione parziale, classifica l'intento e seleziona il filler verbale o gestuale da riprodurre nei primi secondi.	T: alterazione di soglie o prompt di classificazione per forzare la selezione di filler errati. E: esecuzione di risposte non autorizzate o estensione del ruolo oltre la generazione del filler.	I, Az
M2 – Deep-Brain Agent	LLM principale responsabile dell'interpretazione completa della richiesta, dell'utilizzo del contesto RAG e della generazione della risposta sostanziale.	T: indirect prompt injection o manipolazione della risposta generata. I: esposizione incontrollata di istruzioni interne o contesti RAG riservati. E: abusi nell'uso di tool per estendere la propria autonomia oltre lo scope assegnato.	C, I, Az
M3 – Personality/System Prompts	Istruzioni operative condivise o coordinate tra Fast-Brain e Deep-Brain per mantenere coerenza di identità, ruolo, tono, comportamento, limiti e obiettivi.	T: manomissione delle istruzioni per causare goal misalignment o rimuovere i guardrail. I: estrazione indiretta del sistema di prompt tramite attacchi di prompt leakage.	C, I
M4 – Embedding e Retrieval Models	Modelli e funzioni utilizzati per generare embedding, confrontare query e documenti, ordinare i risultati e selezionare il contesto inviato al Deep-Brain.	T: alterazione dei parametri di embedding per alterare i punteggi di similarità o favorire documenti malevoli. I: inversione degli embedding per ricostruire il testo di documenti riservati.	C, I
M5 – VAD e Streaming STT Models	Modelli che rilevano l'attività vocale e trasformano progressivamente l'audio in partial transcript e trascrizione completa.	S: audio sintetico o attacchi di replay interpretati dal VAD/STT come voce reale dell'utente. T: rumore avversariale impercettibile inserito nell'audio per alterare la trascrizione.	Au, I
M6 – TTS e Voice-Cloning Models	Modelli che trasformano filler e risposta principale in audio e riproducono la voce associata al personaggio.	S: generazione non autorizzata di tracce audio per impersonare il digital human (voice spoofing). T: alterazione dei parametri di sintesi vocale per distorcere tono, prosodia o contenuto.	Au, I
M7 – Video Generation Model	Modello utilizzato dal Background Path per generare il video principale a partire dalla richiesta, dal personaggio e dagli artefatti di riferimento.	S: sintesi di frame o video malevoli presentati come output ufficiali del personaggio. D: sovraccarico di richieste computazionalmente onerose per saturare la risorsa e bloccare il Background Path.	Au, A

Continua nella pagina successiva

Tabella 4 – continuazione

Asset	Descrizione	STRIDE-AI Relevance	Proprietà violata
M8 – Lip-Sync e Animation Models	Modelli multimodali che sincronizzano voce, movimento delle labbra, espressioni, gesti e frame del personaggio.	T : alterazione dei parametri di sincronizzazione o iniezione di artefatti visivi impropri. D : errore di rendering o eccezione nel modello che interrompe la riproduzione dello streaming video.	I, A
M9 – Request Router e Orchestration Logic	Codice e regole che ricevono l'input, avviano in parallelo Instant Path e Background Path, associano risultati e sessioni e gestiscono timeout, retry, code e priorità.	T : manomissione delle regole di routing per bypassare i controlli o inviare dati alla sessione errata. D : loop di invocazione, race condition o esaurimento code per bloccare l'orchestratore. E : violazione dei confini di isolamento tra Instant e Background Path.	I, A, Az
M10 – Swap Manager e Stitching Logic	Logica che decide quando terminare il filler, quando avviare il contenuto principale e come unire audio e video senza sovrapposizioni o discontinuità.	S : iniettare un falso segnale di completamento (<i>Video Ready Signal</i>) per forzare uno swap prematuro. T : alterazione dello stato di transizione causando sovrapposizione audio/video o miscelazione di sessioni.	Au, I

6.3 Considerazioni sulla classificazione

La separazione tra *Data Assets* e *Model Assets* si basa sul ruolo prevalente svolto dal singolo elemento all'interno dell'architettura agentica.

In particolare, i **Personality Source Artifacts** (D7) sono classificati come dati poiché costituiscono i contenuti sorgente, persistenti e versionabili, utilizzati per definire la conoscenza e l'identità del personaggio. Diversamente, i **Personality/System Prompts** (M3) rientrano nei *Model Assets* in accordo con le specifiche della traccia, poiché rappresentano le istruzioni operative runtime iniettate nel contesto dei modelli per condizionarne direttamente il comportamento.

Tale distinzione previene sovrapposizioni analitiche:

- **D7** protegge l'integrità e la riservatezza del materiale sorgente da cui viene derivata la personalità;
- **M3** protegge la formulazione operativa e l'esecuzione contestuale delle istruzioni fornite agli agenti.

I componenti di coordinamento (*Request Router*, *Orchestration Logic* e *Swap Manager*), pur non essendo modelli di Machine Learning in senso stretto, vengono inclusi tra i *Model Assets* adottando una visione architetturale estesa. Essi governano infatti l'autonomia e la logica decisionale del sistema, determinando il routing dei dati, la concorrenza tra i percorsi (*Instant* e *Background Path*), l'isolamento delle sessioni e la gestione delle transizioni.

Infine, la mappatura delle proprietà di sicurezza *CIA*³-R associate a ciascun asset costituisce il presupposto metodologico per le successive sezioni, in cui verranno valutate l'applicabilità, la probabilità (*likelihood*) e l'impatto (*severity*) delle minacce (inclusa la tassonomia OWASP Top 10 per LLM/AI).

7 Analisi delle Minacce basata su OWASP Agentic Top 10

In conformità con i requisiti del progetto, l'analisi delle minacce viene strutturata attorno ai dieci rischi definiti dall' **OWASP Top 10 for Agentic Applications 2026**. La Tabella 5 associa ciascuna categoria OWASP alle minacce concrete individuate nell'architettura Dual-Brain, evidenziando gli asset impattati e il livello di priorità.

Tabella 5: Matrice unificata delle minacce OWASP Agentic e asset impattati.

Rischio OWASP	Threat Concreta e Motivazione nella Pipeline	Asset Impattati	Proprietà CIA³-R Violate	Priorità
ASI01 Agentic Goal Hijacking	L'input utente parziale in streaming induce il Fast-Brain a deviare dal system prompt, producendo gesti o filler inappropriati entro i 800 ms.	D2, M1, D5	I, Az	Alta
ASI02 Tool Misuse & Exploitation	Manipolazione dei parametri o abuso nell'invocazione dei servizi di rendering video (Veo 3.1), TTS, voice cloning o lip-sync.	D10, D9	I, Az	Alta
ASI03 Identity & Privilege Abuse	Uso di credenziali o token condivisi tra Fast-Brain, Deep-Brain e microservizi multimediali, con potenziale escalation di privilegi.	D8	Az, Au	Alta
ASI04 Agentic Supply Chain	Compromissione di librerie di terze parti, dell'indice FAISS, del modello Falcon-Arabic-7B o dei servizi cloud di generazione video/audio.	M1, M2, D8	I, C	Media
ASI05 Unexpected Code Execution	Generazione o interpretazione dinamica di codice/script durante il ragionamento del Deep-Brain o la logica di orchestrazione.	M2, D10	I, Az	Media
ASI06 Memory & Context Poisoning	Iniezione di dati o feedback malevoli che alterano la memoria di sessione, la base di conoscenza RAG o il ranking dei documenti in FAISS.	D4, D12	I, Ac	Alta

Rischio OWASP	Threat Concreta e Motivazione nella Pipeline	Asset Impattati	Proprietà CIA ³ -R Violate	Priorità
ASI07 Insecure Inter-Agent Comm.	Tampering, replay o assenza di autenticazione nei messaggi asincroni tra Fast-Brain, Deep-Brain, Orchestratore e Swap Manager (<i>Double-Speak</i>).	D10	I, A, Au	Medio-Alta
ASI08 Cascading Failures	Attacchi di flooding o query costose sul Deep-Brain saturano GPU e rendering video, provocando il blocco asincrono dello Swap Manager.	D1, M7	A	Media
ASI09 Human-Agent Trust Exploitation	Abuso dell'aspetto avatar, della voce clonata e della personalità empatica dell'agente per indurre la fiducia dell'utente o erogare consigli dannosi.	D7, D8, M6	C, Au	Medio-Alta
ASI10 Rogue Agents	Deviazione o drift persistente del modello, della policy o dei prompt dalla personalità definita per Al-Hakima senza che il sistema lo rilevi.	M1, M2, D7	I, Ac	Medio-Bassa

8 Risk Prioritization

8.1 Criteri di Valutazione e Metodologia

La prioritizzazione dei rischi adotta un approccio qualitativo basato sulla combinazione di probabilità di accadimento (*Likelihood*) e gravità delle conseguenze (*Severity*), in conformità con la metodologia STRIDE-AI [14] e con il framework OWASP AIVSS presentato a lezione [2]. Per mantenere l'analisi snella ed efficace, si evita l'impiego del calcolo quantitativo dell'RPN (*Risk Priority Number*), prediligendo una classificazione categoriale.

La **Likelihood** misura la fattibilità dell'attacco considerando l'accessibilità del vettore, i privilegi richiesti, la complessità tecnica, la ripetibilità e i controlli o *guardrails* esistenti.

La **Severity** misura la gravità dell'impatto potenziale sui pilastri di sicurezza (Confidenzialità, Integrità e Disponibilità), valutando i dati esposti, la persistenza del danno (es. inquinamento della memoria), il numero di utenti coinvolti, la propagazione ad altri moduli, la perdita di autenticità e il danno reputazionale.

Inoltre, il calcolo integra i quattro amplificatori agentici definiti nelle metriche AIVSS [2]:

- **Autonomia dell'agente:** il grado di indipendenza decisionale ed esecutiva;
- **Memoria persistente:** il livello di conservazione e riutilizzo dello stato (es. Vector DB);
- **Interazione multi-agente:** la complessità dello scambio di dati e comandi tra agenti;

- **Criticità della decisione e potere persuasivo:** l'impatto potenziale degli output verso utenti o sistemi downstream.

8.2 Matrice Qualitativa di Rischio

La combinazione di *Likelihood* e *Severity* determina la classe di rischio qualitativa su tre livelli (**Basso**, **Medio**, **Alto**).

Tabella 6: Matrice qualitativa di valutazione del rischio (Likelihood × Severity).

	Severity Basso	Severity Media	Severity Alta
Likelihood Alta	Medio	Alto	Alto
Likelihood Media	Basso	Medio	Alto
Likelihood Basso	Basso	Basso	Medio

8.3 Priorità dei rischi principali

Tabella 7: Valutazione dei rischi prioritari.

ID	Rischio	Lik.	Impact	Risk	Amplificatori agentici
R1	Goal hijack del Fast-Brain	Alta	Alto	Critico	Output immediato, contesto parziale, human trust
R2	Feedback poisoning persistente	Alta	Alto	Critico	Persistenza, effetto cross-session, modifica del few-shot pool
R3	Identity/privilege abuse tra agenti	Media	Alto	Alto	Multi-agent, credenziali, accesso a memoria e tool
R4	Tampering/replay inter-agent	Media	Alto	Alto	Esecuzione asincrona, state machine e correlazione sessione
R5	Voice clone abuse e trust exploitation	Media	Alto	Alto	Identità biometrica, output persuasivo, difficile attribution
R6	Supply-chain compromise	Media	Alto	Alto	Molti servizi esterni, persistenza e difficile rilevazione
R7	Cascading failure/DoS	Media	Medio	Medio	Percorsi paralleli e risorse condivise

Per evitare falsa precisione, non viene assegnato un AARS numerico in assenza del calcolatore e della formula completa utilizzati dal corso. Per i rischi R1–R5 si conserva comunque un vettore descrittivo di exploitability e impatto nella sezione successiva.

9 Scenari di minaccia prioritari

9.1 Scenario 1 — Goal hijack del Fast-Brain

Classificazione: STRIDE Tampering; OWASP ASI01, con possibile propagazione verso ASI09.

Asset: partial transcript, system/personality prompt, Fast-Brain, filler, trigger JSON.

Precondizioni: l'attaccante può inviare voce o testo; il Fast-Brain opera su input parziale; l'output viene sintetizzato prima della risposta principale.

Attack path:

1. L'attaccante inserisce nei primi token un'istruzione che tenta di ridefinire il compito del Fast-Brain.
2. Lo STT produce un partial transcript privo del contesto che seguirebbe nella frase completa.
3. Il modello interpreta l'istruzione come prioritaria rispetto al ruolo di semplice filler.
4. Viene prodotto un filler che risponde alla domanda, chiede dati sensibili o induce l'utente a compiere un'azione.
5. Il contenuto viene pronunciato prima che il Deep-Brain e i controlli del percorso principale possano correggerlo.

Impatto: compromissione dell'integrità conversazionale, social engineering, possibile disclosure di PII e perdita di fiducia.

Vettore qualitativo ispirato ad AIVSS: AV:N, AC:L, AT:N, PR:N, UI:P; C:M, I:H, A:L; autonomia media, memoria bassa, multi-agent media, trust impact alto.

Detection signals: filler interrogativi, richiesta di PII, presenza di imperativi, overlap semantico con una risposta sostanziale, trigger non coerente, violazione del limite di parole.

Controlli chiave: least agency, JSON Schema, trigger enum, content policy deterministica, PII detection, timeout e filler statico pre-approvato.

9.2 Scenario 2 — Feedback poisoning persistente

Classificazione: STRIDE Tampering e Repudiation; OWASP ASI06.

Asset: feedback esplicito/implicito, ranking, FAISS metadata, few-shot pool, audit trail.

Precondizioni: il feedback influenza ranking o selezione degli esempi; i contributi non sono sufficientemente autenticati, deduplicati o limitati.

Attack path:

1. L'attaccante crea più sessioni o account e ripete feedback positivi su risposte associate a chunk malevoli.
2. In parallelo penalizza chunk corretti tramite feedback negativo o replay.
3. Il sistema aggiorna score o promuove esempi nel few-shot pool senza una soglia robusta e senza provenienza affidabile.
4. Le query future recuperano più frequentemente contenuto manipolato.
5. Il Deep-Brain produce risposte distorte per utenti diversi dall'attaccante.

Impatto: integrità compromessa in modo persistente, effetto cross-session, difficile rollback se non esistono versioning e audit.

Vettore qualitativo: AV:N, AC:L-M, AT:N, PR:L, UI:N; C:L, I:H, A:L; autonomia media, memoria alta, multi-agent media, decision criticality media-alta.

Detection signals: burst di feedback, account correlati, distribuzioni anomale, variazioni improvvise del top- k , promozione di chunk senza evidenza sufficiente.

Controlli chiave: feedback autenticato, rate limit, anti-replay, robust aggregation, separazione fra feedback e update persistente, provenance, versioning, rollback e HITL per promozioni ad alto impatto.

9.3 Scenario 3 — Identity and privilege abuse tra agenti

Classificazione: STRIDE Elevation of Privilege e Spoofing; OWASP ASI03.

Asset: service account, API token, endpoint RAG, memoria, orchestratore.

Precondizioni: Fast-Brain e Deep-Brain condividono credenziali oppure le API non verificano lo scope dell'identità chiamante.

Attack path:

1. Il Fast-Brain viene compromesso tramite goal hijack o supply-chain compromise.
2. Il processo usa il token condiviso per invocare un endpoint riservato al Deep-Brain.
3. Legge memoria, recupera dati non necessari o propone una modifica persistente.
4. L'azione appare provenire da un'identità legittima e può non essere distinta nei log.
5. Il blast radius passa dal solo filler all'intera pipeline.

Impatto: accesso non autorizzato a memoria e contesto, possibile esfiltrazione, modifica persistente e compromissione dell'orchestratore.

Vettore qualitativo: AV:A/N, AC:M, AT:P, PR:L, UI:N; C:H, I:H, A:M; autonomia alta dopo la compromissione, memoria alta, multi-agent alta.

Detection signals: chiamate RAG dall'identità Fast-Brain, uso di scope anomali, token fuori contesto, accessi incompatibili con il ruolo.

Controlli chiave: identità distinte, token short-lived, audience e scope binding, deny-by-default, policy enforcement point, network segmentation e audit per azione cross-agent.

9.4 Scenario 4 — Tampering e replay dei messaggi inter-agent

Classificazione: STRIDE Tampering e Spoofing; OWASP ASI07.

Asset: messaggi Fast-Brain/orchestratore, trigger, sequence number, session ID, completion signal.

Precondizioni: il canale o il message bus non garantisce autenticità end-to-end, freschezza e binding alla sessione.

Attack path:

1. L'attaccante intercetta o ottiene un messaggio valido del Fast-Brain.
2. Modifica il trigger oppure reinvia il messaggio in una sessione diversa.
3. L'orchestratore verifica solo la correttezza sintattica del JSON.
4. Il messaggio viene accettato come fresco e proveniente dall'agente corretto.
5. L'avatar esegue un gesto errato, riproduce un filler non correlato o entra in uno stato inconsistente.

Impatto: corruzione dello stato, output inappropriato, race condition, potenziale cascading failure.

Vettore qualitativo: AV:A, AC:M, AT:P, PR:L, UI:N; C:L, I:H, A:M; multi-agent alta.

Detection signals: sequence duplicate, timestamp fuori finestra, session mismatch, agent ID non coerente, ordine degli stati impossibile.

Controlli chiave: mTLS o identità workload equivalente, autenticazione applicativa quando il bus persiste i messaggi, nonce/sequence, expiry, idempotency key e state machine deterministica.

9.5 Scenario 5 — Voice clone abuse e human-agent trust exploitation

Classificazione: STRIDE Spoofing e Information Disclosure; OWASP ASI03, ASI04 e ASI09.

Asset: Therapist WAV, voice embedding, credenziali TTS, personality prompt, output finale e meta-data.

Precondizioni: l'attaccante ottiene il voice asset, il relativo embedding o le credenziali del servizio di clonazione.

Attack path:

1. Il voice asset viene copiato tramite storage mal configurato, insider o provider compromesso.
2. L'attaccante genera audio nella voce dell'avatar e produce un video coerente.
3. Il contenuto usa tono, formule linguistiche e gesti associati alla personalità legittima.
4. L'utente attribuisce il messaggio al sistema autentico.
5. Il contenuto può chiedere PII, promuovere rimedi non sicuri o fornire indicazioni fraudolente.

Impatto: impersonazione highly credibile, danno reputazionale, disclosure di dati, rischio di guida dannosa e difficile attribution.

Vettore qualitativo: AV:N, AC:M, AT:P, PR:L/H, UI:A; C:H, I:H, A:L; trust impact molto alto.

Detection signals: accessi anomali al voice vault, generazioni senza sessione valida, assenza di provenance, output non associato a un audit ID.

Controlli chiave: voice vault cifrato, accesso esclusivo del voice service, credenziali temporanee, watermark/provenance, audit, revoca, disclosure chiara della natura sintetica e policy che vieta richieste di PII.

10 Controlli secondo le sette precauzioni

10.1 Precauzione 1 — Least Agency

Least Agency estende least privilege alle capacità di ragionamento, memorie, tool e azioni dell'agente [2]. Applicazioni concrete:

- il Fast-Brain può produrre soltanto filler, intent label e trigger appartenenti a una whitelist;
- il Fast-Brain non accede a FAISS, memoria persistente, feedback store, voice asset o generazione video;
- il Deep-Brain usa il RAG in read-only durante l'inferenza;
- il Feedback Manager propone aggiornamenti, ma non promuove autonomamente contenuti ad alto impatto;
- l'orchestratore applica una sequenza deterministica e non interpreta output come codice;
- ogni identità ha scope, audience e durata minima necessari.

10.2 Precauzione 2 — Guardrail deterministici e HITL

Guardrail sincroni sul Fast-Brain:

- JSON Schema strict;
- filler con lunghezza massima;
- trigger da enum;
- divieto di richieste di PII e di consigli sostanziali;
- filtro per domande, imperativi e contenuti fuori policy;
- session binding e sequence validation;
- fallback statico quando un controllo fallisce o il timeout scade.

HITL per azioni ad alto impatto:

- modifica del voice asset o del personality prompt;
- promozione persistente nel few-shot pool;
- modifica del set di trigger o delle policy;
- rilascio di nuovi modelli o provider;

- aggiornamenti permanenti dell'indice RAG;
- output in domini sensibili quando il sistema formula raccomandazioni mediche o finanziarie.

10.3 Precauzione 3 — Sandboxing e controllo granulare degli accessi

- container o runtime isolati per agenti, TTS, voice service e lip-sync;
- identità workload separate e token short-lived;
- deny-by-default su rete e file system;
- voice asset in storage dedicato, cifrato e accessibile solo al voice service;
- FAISS read-only nel serving path e update path separato;
- egress control verso provider esterni;
- quote e limiti di risorse per prevenire cascading failure.

10.4 Precauzione 4 — Audit trail completo e immutabile

L'audit trail deve registrare:

- input e transcript, con protezioni per i dati sensibili;
- partial transcript inviato al Fast-Brain;
- versione di modello, prompt, policy e schema;
- filler, trigger, risultato dei controlli e fallback;
- agent identity, tool invocation, timestamp e outcome;
- chunk RAG recuperati, score e provenance;
- feedback, deduplicazione e modifiche a ranking/few-shot;
- accessi al voice asset e generazioni del voice service;
- transizioni della state machine e timeout.

Non è necessario memorizzare ragionamenti privati completi. Per la ricostruzione dell'incidente sono sufficienti decision trace, input/output, tool call, policy decision e motivazione sintetica.

10.5 Precauzione 5 — Supply chain control

- registry approvato per modelli e container;
- firme, hash e versioni bloccate;
- SBOM per librerie, servizi e modelli;
- scansione delle dipendenze e verifica della serializzazione sicura;
- test in shadow mode prima del rilascio;
- rollback rapido di modelli, prompt e policy;
- due diligence sui provider TTS, voice e video;
- registrazione della versione di ogni componente usato per generare l'output.

10.6 Precauzione 6 — Continuous execution monitoring

Il monitoraggio deve rilevare:

- filler che risponde alla domanda o richiede dati;
- goal drift e trigger anomali;
- accessi incompatibili con il ruolo dell'agente;

- replay, session mismatch e sequence duplicate;
- burst di feedback e variazioni anomale del top- k ;
- consumo GPU, timeout, retry e loop;
- Double-Speak e transizioni di stato impossibili;
- generazioni vocali prive di sessione o audit ID;
- deviazioni persistenti dopo un aggiornamento.

Devono esistere kill-switch, circuit breaker, limiti massimi di passi e graceful degradation.

10.7 Precauzione 7 — Audit periodici ispirati ad AIVSS

Gli audit devono essere ripetuti:

- dopo ogni modifica a modello, prompt, memoria o tool;
- quando cambia il livello di autonomia;
- quando viene aggiunto un nuovo provider;
- dopo incidenti o rilevazioni di drift;
- periodicamente tramite red teaming multilingue e multimodale.

L'audit riesamina vettore d'attacco, complessità, requisiti, privilegi, interazione utente, impatto CIA e amplificatori agentici.

11 Secure architecture proposal

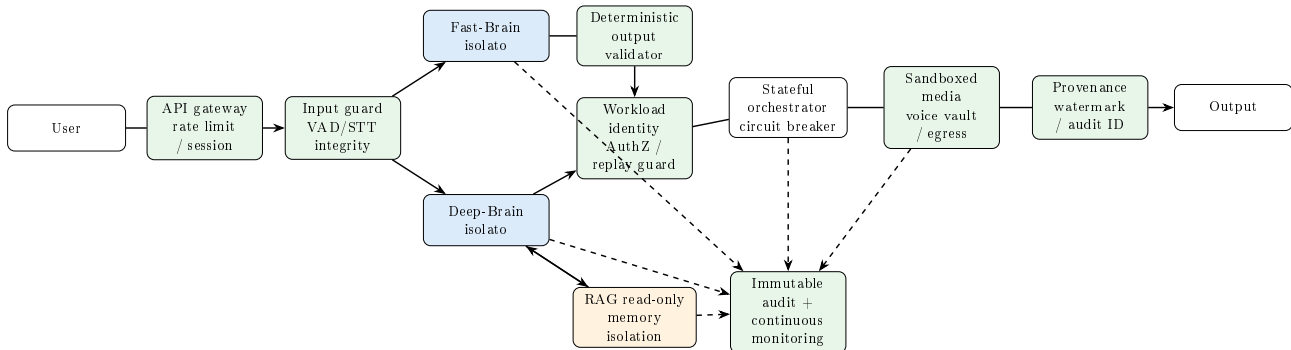


Figura 5: Secure architecture proposta.

Tabella 8: Controlli per trust boundary.

TB	Controllo	Funzione	Threat ridotte
TB1	API gateway, rate limit, session management	Limita abuso dell'input e associa ogni richiesta a un principal	T1, T2, T8, T9
TB2	Input guard e partial/full transcript correlation	Controlla formato, durata, lingua e coerenza dei transcript	T1, T2
TB3	Workload identity, AuthZ, schema, nonce e sequence	Autentica agenti e messaggi, impedisce accessi fuori ruolo e replay	T4, T5
TB4	RAG read-only, update gate, provenance e versioning	Separa serving e update, limita poisoning persistente	T3, T4, T12
TB5	Sandboxing, voice vault, egress control e signed artifacts	Limita tool misuse, furto della voce e supply-chain impact	T6, T7, T11
TB6	Provenance, watermark, audit ID e transparency disclosure	Rafforza autenticità e attribution dell'output	T6, T9, T11

11.1 Fail-safe behavior

Il sistema non deve scegliere fra sicurezza e latenza. Se il Fast-Brain non produce un output valido entro il budget, l'orchestratore usa un filler statico pre-approvato oppure mantiene un'animazione idle sicura. Non deve mai inoltrare un output non validato soltanto per rispettare il tempo target.

12 Trade-off sicurezza–latenza

I controlli sono suddivisi in base al loro posizionamento nel percorso critico.

Tabella 9: Posizionamento dei controlli.

Classe	Esempi	Posizionamento	Overhead atteso
Sincroni deterministici	JSON Schema, enum, length check, session/sequence binding, allow/deny policy	Prima del TTS filler	Trascurabile o basso; da misurare
Sincroni leggeri	PII detection, request rate limit, classificatore di policy compatto	Edge e output validator	Basso; da misurare
Asincroni	Anomaly detection, analisi feedback, correlazione dei log, drift monitoring	Fuori dal critical path	Non blocca il filler
Offline	Red teaming, scansione supply chain, AIVSS audit, model evaluation	CI/CD e audit periodico	Nessun impatto runtime

Non vengono indicati valori in millisecondi non misurati. La validazione sperimentale dovrà quantificare l'overhead reale e il tasso di attivazione del fallback.

13 Piano di validazione sperimentale

Questa sezione definisce esperimenti riproducibili. Non vengono presentati risultati empirici perché non sono ancora stati eseguiti. Le tabelle sono predisposte per essere completate dopo l'implementazione.

13.1 Esperimento A — Fast-Brain security harness

Obiettivo: verificare che il validator impedisca filler e trigger fuori policy senza introdurre un overhead incompatibile con il fast path.

Dataset:

- input benigni;
- direct prompt injection nei primi token;
- input troncati e ambigui;
- inglese, arabo standard, dialetto emiratino e code-switching;
- richieste di PII e consigli sostanziali;
- output JSON malformati o con trigger non autorizzato.

Metriche: policy violation rate, invalid JSON rate, unsafe filler rate, fallback activation rate, false positive rate e tempo di validazione.

Tabella 10: Template risultati Esperimento A.

Metrica	Baseline	Con controlli	Target/nota
Unsafe filler rate	Da misurare	Da misurare	Riduzione significativa
Invalid trigger accepted	Da misurare	Da misurare	0
False positive rate	–	Da misurare	Compatibile con UX
Validation latency	–	Da misurare	Entro il budget definito
Fallback activation rate	–	Da misurare	Monitorato, non nascosto

13.2 Esperimento B — Feedback poisoning simulation

Obiettivo: confrontare un aggiornamento diretto del ranking con un sistema protetto da autenticazione, rate limit, deduplicazione, anti-replay, robust aggregation e update gate.

Metriche: numero di feedback richiesto per portare un chunk malevolo nel top- k , percentuale di query compromesse, tempo di rilevamento e correttezza del rollback.

Tabella 11: Template risultati Esperimento B.

Metrica	Baseline	Sistema sicuro	Interpretazione
Feedback per entrare nel top- k	Da misurare	Da misurare	Più alto è migliore
Query compromesse	Da misurare	Da misurare	Più basso è migliore
Replay accettato	Da misurare	Da misurare	Target: no
Tempo di rollback	–	Da misurare	Ripristino della versione precedente

13.3 Esperimento C — Sicurezza dei messaggi inter-agent

Obiettivo: verificare il rifiuto di trigger modificati, session mismatch, duplicate sequence, messaggi scaduti e agent ID falsi.

Tabella 12: Test case dei messaggi inter-agent.

Test	Controllo atteso	Esito atteso
Trigger modificato	Schema + signature/MAC applicativo se richiesto	Rifiutato
Session ID diverso	Session binding	Rifiutato
Sequence duplicata	Replay cache / idempotency	Rifiutato
Timestamp fuori finestra	Expiry check	Rifiutato
Agent ID falso	Workload identity e authorization	Rifiutato
Filler oltre il limite	Schema e content policy	Fallback

14 Rischio residuo

Tabella 13: Valutazione qualitativa del rischio residuo atteso.

Scenario	Controlli principali	Iniziale	Residuo	Motivazione
Goal hijack Fast-Brain	Least agency, validator, fallback, monitoring	Critico	Medio	I guardrail riducono l'impatto, ma input linguistici adattivi restano possibili
Feedback poisoning	Auth feedback, update gate, robust aggregation, rollback	Critico	Medio	La persistenza è confinata e reversibile, ma Sybil sofisticati restano un rischio
Privilege abuse	Identità separate, token short-lived, policy deny-by-default	Alto	Basso-Medio	Il Fast-Brain non possiede più gli accessi utili alla propagazione
Replay inter-agent	Workload identity, nonce, sequence, expiry	Alto	Basso	Messaggi non freschi o fuori sessione vengono rifiutati
Voice clone abuse	Voice vault, provenance, audit, revoca	Alto	Medio	Un output sintetico ottenuto fuori sistema può essere difficile da eliminare completamente

Il rischio residuo deve essere rivalutato dopo la validazione sperimentale. I valori sopra rappresentano una previsione progettuale, non risultati misurati.

15 Limitazioni

- L'architettura è descritta a livello progettuale; deployment, provider e protocolli effettivi possono modificare likelihood e controlli necessari.
- Non sono stati eseguiti test empirici; la sezione di validazione contiene un piano e template di risultati.
- La valutazione del rischio è qualitativa. Non viene calcolato un AARS numerico senza lo strumento e la formula usati nel corso.
- La robustezza multilingue e dialettale dei guardrail deve essere verificata sperimentalmente.
- Il threat model non dimostra l'assenza di backdoor nei modelli; riduce il rischio tramite provenance, firme, testing e rollback.
- Privacy, compliance e consenso per voice cloning richiedono un'analisi dedicata oltre al threat model tecnico.
- L'uso dell'avatar in contesti di salute aumenta la decision criticality e richiede policy di contenuto e supervisione umana più restrittive.

16 Conclusioni

La pipeline dual-brain riduce la latenza percepita, ma introduce superfici d'attacco specifiche: il Fast-Brain agisce su input parziale, i due agenti devono coordinarsi, memorie e feedback possono persistere, e l'output audiovisivo sfrutta una forte identità umana. Il rischio non deriva soltanto dal modello linguistico, ma dall'interazione fra identità, memoria, tool, orchestrazione e fiducia dell'utente.

Il threat modeling ha mostrato come i rischi prioritari siano goal hijack, feedback poisoning, identity/privilege abuse, comunicazione inter-agent insicura e abuso della voce clonata. ASI05 è stato correttamente considerato non applicabile nello scope corrente, evitando di introdurre scenari RCE non supportati dall'architettura.

La strategia proposta applica le sette precauzioni del corso e adotta un principio centrale: **la bassa latenza non deve mai giustificare il bypass dei controlli**. I controlli deterministici restano nel fast path; monitoraggio, audit e analisi più costose operano in modo asincrono; in caso di errore il sistema usa un fallback statico sicuro. La separazione delle identità e la least agency limitano il blast radius, mentre provenance, voice vault e update gate proteggono gli asset più caratterizzanti della pipeline.

Il passo successivo è implementare il security harness e la simulazione di feedback poisoning, completando le tabelle sperimentali con valori misurati. Questo permetterà di trasformare il threat model progettuale in una valutazione verificata e riproducibile.

A JSON Schema semplificato del Fast-Brain

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "type": "object",
  "additionalProperties": false,
  "required": ["session_id", "intent", "trigger", "filler", "sequence"],
  "properties": {
    "session_id": {"type": "string", "minLength": 16, "maxLength": 128},
    "intent": {
      "type": "string",
      "enum": [
        "complex_analytical",
        "opinion_affective",
        "factual_search",
        "controversial_defensive",
        "generic_acknowledgement"
      ]
    },
    "trigger": {
      "type": "string",
      "enum": [
        "GAZE_UP_LEFT",
        "HEAD_NOD_SLIGHT",
        "LEAN_IN_BOOK",
        "HAND_GESTURE_OPEN",
        "IDLE_THINKING"
      ]
    },
    "filler": {"type": "string", "minLength": 1, "maxLength": 120},
    "sequence": {"type": "integer", "minimum": 0}
  }
}
```

```
}
```

La lunghezza in caratteri non sostituisce il controllo applicativo sul numero di parole. Il validator deve inoltre applicare content policy, PII detection e divieto di richieste all'utente.

B Formato sicuro del messaggio inter-agent

```
{
  "message_id": "uuid",
  "session_id": "9f4b...",
  "agent_id": "fast-brain-prod-eu-01",
  "audience": "orchestrator-prod-eu",
  "issued_at": "2026-07-23T14:22:18Z",
  "expires_at": "2026-07-23T14:22:20Z",
  "sequence": 12,
  "idempotency_key": "9f4b...:12",
  "payload": {
    "intent": "complex_analytical",
    "trigger": "GAZE_UP_LEFT",
    "filler": "That is an important question; let me think carefully."
  },
  "policy_version": "fastbrain-policy-3.2",
  "schema_version": "1.0"
}
```

Il trasporto deve autenticare l'identità del workload. Se il messaggio è persistito, inoltrato attraverso più trust domain o necessita di verifica end-to-end, è opportuno aggiungere una firma o un MAC applicativo. Sequence, expiry e idempotency impediscono replay e duplicazione.

C Matrice di tracciabilità

Tabella 14: Tracciabilità threat–controlli–test.

Threat	OWASP / STRIDE	Controlli	Validazione
Goal hijack	ASI01 / Tampering	Least agency, validator, fallback	Esperimento A: prompt injection multilingue
Feedback poisoning	ASI06 / Tampering	Auth, anti-replay, update gate, rollback	Esperimento B: top- <i>k</i> poisoning simulation
Privilege abuse	ASI03 / EoP	Workload identity, scoped token, AuthZ	Test negativo: Fast-Brain chiama endpoint RAG
Inter-agent replay	ASI07 / Spoofing, Tampering	Nonce, sequence, expiry, session binding	Esperimento C
Voice clone abuse	ASI09 / Spoofing, Disclosure	Voice vault, provenance, audit, revoca	Test accessi e generazioni senza audit ID

Threat	OWASP / STRIDE	Controlli	Validazione
Supply chain	ASI04 / Tampering	Firma, SBOM, scanning, shadow mode	Verifica artefatto e rollback
Cascading failure	ASI08 / DoS	Quote, timeout, circuit breaker, fallback	Load e fault-injection test

Riferimenti bibliografici

- [1] Project specification, *Agentic filler loop and dual-brain architecture for a real-time digital human pipeline*, materiale di progetto, 2026.
- [2] E. Damiani, *Security Precautions for Agentic Systems: Seven Key Practices for Safe Data-Intensive Architectures*, slide del corso Sicurezza delle Architetture Data Intensive, Università degli Studi di Milano, 20 aprile 2026.
- [3] E. Damiani, *Talking Avatar with RAG Pipeline using Veo 3.1: Asset Model, Failure Modes, and Threat Analysis using STRIDE-AI*, slide del corso, 4 maggio 2026.
- [4] Project material, *The Legend of Al-Hakima Umm Saif e Core Personality Traits* (inclusi *Character Legend* e *Personality Traits*), 2026.
- [5] Project material, *Verbal Habits & Response Guidelines*, 2026.
- [6] L. Mauri and E. Damiani, “STRIDE-AI: An Approach to Identifying Vulnerabilities of Machine Learning Assets,” *IEEE International Conference on Cyber Security and Resilience*, 2021.
- [7] L. Mauri and E. Damiani, “Modeling Threats to AI-ML Systems Using STRIDE,” *Sensors*, 2022.
- [8] OWASP Foundation, *OWASP Top 10 for Agentic Applications 2026*, 2026.
- [9] OWASP Foundation, *OWASP Top 10 for Large Language Model Applications 2025*, 2025.
- [10] S. Yao et al., “ReAct: Synergizing Reasoning and Acting in Language Models,” 2023.
- [11] NIST, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, 2023.
- [12] MITRE, *ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems*.
- [13] IETF, *Security Architecture for WebRTC e WebRTC Security Considerations*, RFC 8827 e RFC 8826, 2021.
- [14] T. N. R. Cyrille e F. Schwarz, *STRIDE-AI: A Threat Modeling Framework for Generative AI Security Assessment*, arXiv preprint arXiv:2605.17163, 2026.